

Introduction to Information Security

1. Define Information. Explain the components of an Information System.

Information refers to processed, structured, or organized data that is meaningful and can be used for decision-making or understanding.

Example: • Raw Data: "75, 80, 90"

• Information: "The average temperature this week is 81°F."

Components of an Information System:

1. **Hardware:** Physical devices like computers, servers, and networking equipment.
2. **Software:** Programs and applications used to process data.
3. **Data:** Raw facts that are processed into meaningful information.
4. **People:** Users, administrators, and IT professionals who interact with the system.
5. **Processes:** Procedures and rules for collecting, processing, and managing information.

2. Define information security and explain its primary objectives.

Information security, often referred to as InfoSec, is the practice of protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction.

● In other words, you want to protect your data and systems from those who seek to misuse them, intentionally or unintentionally, or those who should not have access to them at all.

The CIA triad consists of Confidentiality, Integrity, and Availability, which are the core objectives of information security.

3. Define information security and briefly describe its domains.

Confidentiality:

Ensuring that data is only accessible to those who have the right to see it. It prevents sensitive information from reaching the wrong people.

Example: ATM transactions require confidentiality of the user's PIN(Personal Identification Number), account information, and bank transaction details.

Confidentiality can be compromised in many ways, such as losing a device with data, someone seeing your password while you type it, sending information to the wrong person, or an attacker breaking into a system.

Integrity:

Integrity is the ability to prevent people from changing your data in an unauthorized or undesirable manner.

File owners may have read and write access, while others may have only read access or no access at all.

For Example:

☞ Modern operating systems like Windows and Linux maintain integrity by using file permissions to prevent unauthorized changes.

☞ If such data is altered—for example, medical test results—it can lead to wrong decisions and serious harm.

Availability:

Availability: refers to the ability to access our data when we need it.

Availability can be lost due to power failure, system or application issues, Server attacks/issue, network attacks or high traffic(same time) the server becomes overloaded.

☞ When such problems are caused by an attacker, it is called a denial-of-service (DoS) attack.

Example: When see the SSC/HSC online result sheet. This is the concept lack of Availability.

Information security, often referred to as InfoSec, is the practice of protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction.

● In other words, you want to protect your data and systems from those who seek to misuse them, intentionally or unintentionally, or those who should not have access to them at all.

Information Security Domains (Exam Essentials)

- **Physical Security:** Protecting hardware, servers, and facilities from physical damage, theft, or unauthorized entry.
- **Network Security:** Safeguarding data while it travels across networks using tools like Firewalls and VPNs.
- **Application Security:** Ensuring software is built without flaws through secure coding and regular patches.
- **Endpoint Security:** Protecting user devices (laptops, phones) from malware using Antivirus or EDR.
- **Identity & Access Management (IAM):** Controlling who can log in and what they can do using MFA and Roles.
- **Incident Response:** Having a step-by-step plan to detect, stop, and recover from a cyberattack.
- **Risk Management:** Identifying potential threats and deciding how to reduce or manage those risks.
- **Compliance & Governance:** Following legal rules and industry standards like GDPR or ISO 27001.

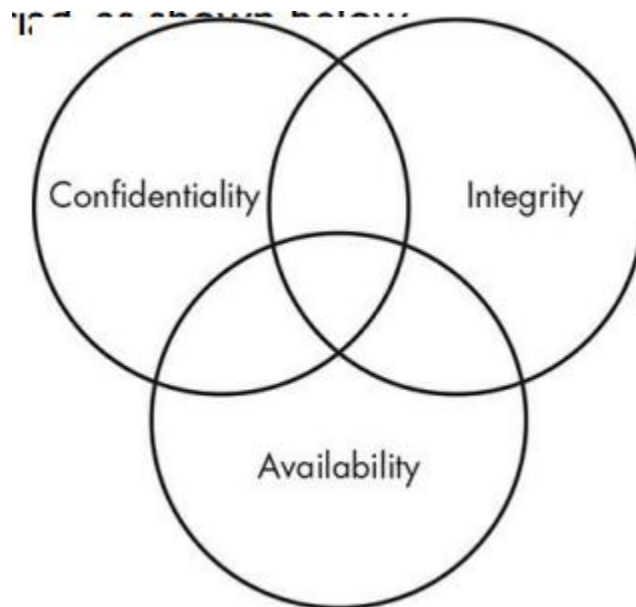
4. What is the CIA triad in information security? Describe each component with an example.

Three of the primary concepts in information security are confidentiality, integrity, and availability, commonly known as the (CIA) triad

The **CIA Triad** is the core model designed to guide policies for information security within an organization. It focuses on three main objectives:

The CIA Triad Breakdown

- **Confidentiality:** Ensuring that sensitive information is accessed only by authorized people.
 - *Goal:* Keep data secret.
 - *Example:* Using **Encryption** or passwords to hide data from hackers.
- **Integrity:** Ensuring that data is accurate, complete, and has not been modified by unauthorized users.
 - *Goal:* Keep data trustworthy.
 - *Example:* Using **Digital Signatures** or Hashing to check if a file was tampered with.
- **Availability:** Ensuring that information and systems are available to authorized users whenever they need them.
 - *Goal:* Keep systems running.
 - *Example:* Having **Backups**, RAID, or protection against DDoS attacks to prevent downtime.



Confidentiality:

Ensuring that data is only accessible to those who have the right to see it. It prevents sensitive information from reaching the wrong people.

Example: ATM transactions require confidentiality of the user's PIN(Personal Identification Number), account information, and bank transaction details.

Confidentiality can be compromised in many ways, such as losing a device with data, someone seeing your password while you type it, sending information to the wrong person, or an attacker breaking into a system.

Integrity:

Integrity is the ability to prevent people from changing your data in an unauthorized or undesirable manner.

File owners may have read and write access, while others may have only read access or no access at all.

For Example:

☞ Modern operating systems like Windows and Linux maintain integrity by using file permissions to prevent unauthorized changes.

☞ If such data is altered—for example, medical test results—it can lead to wrong decisions and serious harm.

Availability:

Availability: refers to the ability to access our data when we need it.

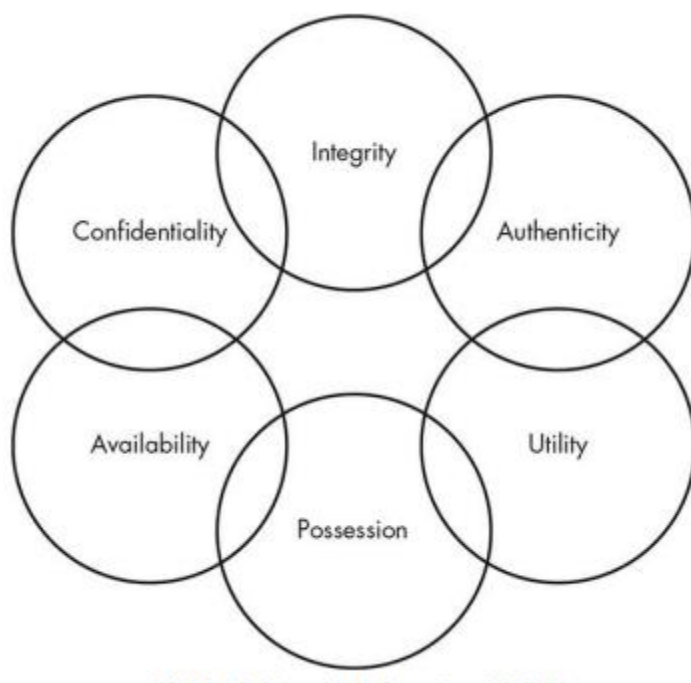
Availability can be lost due to power failure, system or application issues, Server attacks/issue, network attacks or high traffic(same time) the server becomes overloaded.

☞ When such problems are caused by an attacker, it is called a denial-of-service (DoS) attack.

Example: When see the SSC/HSC online result sheet. This is the concept lack of Availability.

5. How does the Parkerian hexad extend the CIA triad? List the additional principles and their significance.

The **Parkerian Hexad** extends the CIA triad by adding three more principles, moving from a 3-element model to a **6-element model**. It provides a more complete picture of security by covering gaps that the CIA triad misses.



Here are the three additional components with examples:

1. Possession or Control

This refers to the physical holding or legal ownership of the data, regardless of whether it is encrypted or "secret."

- **The Difference:** In the CIA triad, if an encrypted laptop is stolen, **Confidentiality** isn't lost (because the thief can't read the data). But in the Parkerian Hexad, you have lost **Possession**.
- **Example:** If a thief steals your suitcase, even if it has a **strong lock** and they can't open it to see your clothes, the fact remains that **you no longer have your suitcase**.

2. Authenticity

- **Authenticity:**

☞ When information is received, determining whether it comes from a trustworthy (valid) source or an untrustworthy (invalid) source is the core concept of authenticity.

The Difference: While Integrity focuses on the data being *correct*, Authenticity focuses on the *validity of the sender*.

- **For example,** fake phone calls often come using the names of bKash, Rocket, Nagad, or different banks. In such cases, verifying whether the call actually comes from the concerned organization is how the authenticity of the information is determined.
- **Example:** An email that looks exactly like it's from your boss, but was actually sent by a hacker (Spoofing). The data might be "correct" (Integrity), but the source is fake (loss of Authenticity).

3. Utility

This refers to the usefulness or "fitness for purpose" of the data. Data must be in a format that is actually helpful to the user.

The level of security applied to information is primarily determined by its market value and importance of Assessment. This is the main focus of the concept of utility.

- **The Difference:** You might have the data (Availability), and it might be correct (Integrity), but if you can't use it, you've lost Utility.
- **Example:** You have a critical report, but it is encrypted and you **lost the decryption key**. The data is "available" on your disk, but it has zero **Utility** because you can't read it.

6. Explain Eugene Spafford's statement about the "only truly secure system." What does it imply about the balance between security and usability?

Spafford's statement about the "only truly secure system

This Meaning: Spafford is saying that Absolute security is impossible. If you want a computer to be 100% safe from hackers, you have to make it so isolated that no one can use it.

- **The Trade-off (Security vs. Usability):**

- **High Security = Low Usability:** Making a system "unhackable" usually makes it too difficult or impossible for people to use.
- **Low Security = High Usability:** Making a system very easy to use (no passwords, no locks) makes it a target for hackers.
- **The Conclusion:** Security is about finding a **balance**. We must protect data while keeping the system functional for the user.

Information Security Attacks

7. Define attacks in the context of information security.

8. Write a short note on the types of attacks.

Attacks:

An **attack** is any attempt to **harm, disrupt, or gain unauthorized access** to a system, network, or data.

You can generally place attacks into one of four categories:

- interception, • interruption, • modification, and • fabrication.

– Each of the categories can affect one or more of the principles of the CIA triad, as shown in Figure.

C	Interception
I	Interruption Modification Fabrication
A	Interruption Modification Fabrication

Interception

Interception is an attack in which an attacker secretly accesses or steals data without authorization.

This attack mainly violates **Confidentiality**, because the attacker can view or use private or sensitive information.

Examples:

- > Stealing or viewing files without permission
- > Eavesdropping on phone calls (Eavesdropping মানে হলো অনুমতি ছাড়া কারও কথাবার্তা বা যোগাযোগ গোপনে শোনা।)
- > Reading someone's emails without authorization

Interruption

Interruption is an attack in which an attacker disables or disrupts a system or service so that users cannot access it.

It mainly affects **Availability**, and sometimes **Integrity**.

Examples:

- > **DoS (Denial of Service) attack** that overloads a server
- > Disrupting database access or operation

DoS (Denial of Service) Attack (Just janar onno):

☞ A DoS attack is an attack where an attacker overloads a system or service, making it unavailable to legitimate users.

Modification:

Modification is an attack in which an attacker alters data, files, or system information.

It mainly affects **Integrity**, because original data is changed. Sometimes it can also affect **Availability**.

Examples:

- > Changing file or database data without permission
- > Modifying server configuration to disrupt services

Fabrication:

Fabrication is an attack in which an attacker creates and inserts **false data, messages, or communications** into a system.

It mainly affects **Integrity**, because fake information is added. Sometimes it can also affect **Availability**.

Examples:

- > Inserting fake data into a database
- > Sending spam or fake messages
- > Creating false communications

Attacks: (K attack korbe keno korbe and kivabe korbe)

1. Threat (হুমকি)

☞ A threat is a possible danger that can cause harm.

Example:

- > **A hacker can steal data.**
- > **A virus can damage your computer files** — this is a threat.
- > **An attacker may try to guess your password** — this is also a threat.

2. Vulnerability (দুর্বলতা)

☞ A vulnerability is a weakness in a system.

Example:

Weak password, outdated software

3. Risk (ঝুঁকি)

☞ Risk is the likelihood of an attack happening.

Example:

Weak password + hacker = high risk

4. Impact (প্রভাব)

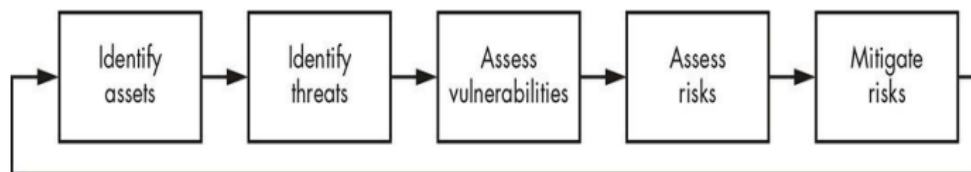
☞ Impact is the damage caused after an attack.

Example:

Money loss, data loss, system down

9. Write a short note on the risk management model.

- Risk management processes compensate for risks in your environment, Figure 4. *As you can see, you need to identify your important assets, figure out*
- *the potential threats against them, assess your vulnerabilities, and then*
- *take steps to mitigate these risks.*



Steps of Risk Management (Exam Friendly)

1. Identify Assets

☞ First, identify the assets that need to be protected.

Examples: Important data, servers, databases.

2. Identify Threats

☞ A threat is a possible danger that can cause harm.

Examples (CIA Triad + Parkerian Hexad):

Which type of threat exist in CIA Triad + Parkerian Hexad model

- **Confidentiality:** If data is leaked, it causes a problem.
- **Integrity:** If data is damaged, incorrect payments may occur.
- **Availability:** If the system goes down, payments cannot be processed.
- **Possession:** If backups are lost, there is a risk.
- **Authenticity:** If the customer is fake, fraudulent transactions may occur.
- **Utility:** If the data is incorrect, it will not be useful.

3. Assess Vulnerabilities

☞ A vulnerability is a weakness in a system.

Example:

-> **Confidentiality:** Data is encrypted and tested regularly, so **no risk**.

-> **Integrity:** Invalid data is rejected during processing, so **no risk**.

- > **Availability:** No database backup means one failure stops payments — **this is a risk.**
- > **Possession:** If encrypted backups are lost, it is **not a risk.**
- > **Authenticity:** If customer identity cannot be verified, **fraud can happen** — this is a **risk.**
- > **Utility:** **If data is checked and correct, it is useful** — not a risk.

4. Assess Risks

☞ Risk is the likelihood of an attack happening.

☞ **Risk = Threat + Vulnerability**

Example:

Availability: If the system goes down, payments cannot be processed.

Because there is **no database backup**, one failure can stop everything.

This creates a **risk** due to a **single point of failure**.

5. Mitigate Risks

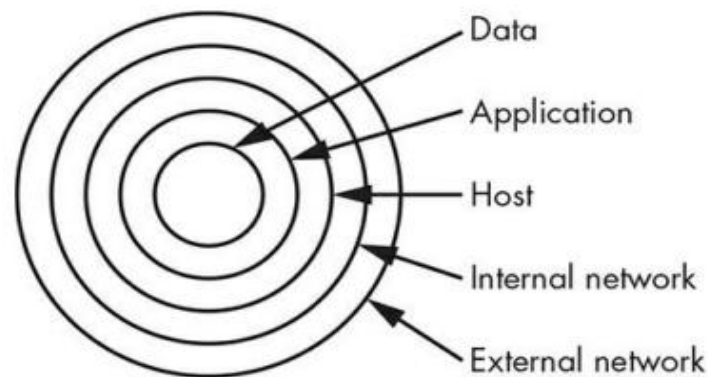
☞ Reduce risks by using different types of controls.

- **Physical Controls:** Locks, guards, CCTV
- **Logical Controls:** Passwords, encryption, firewalls
- **Administrative Controls:** Policies, rules, password policies

10. Write a short note on Defense in Depth.

- **The Concept:** It is a **multilayered defense** strategy. Instead of relying on a single strong wall, you build many different layers of protection around your data.
- **The Goal:** To provide redundancy. If a hacker breaks through the "External Network" layer, they still have to face the "Internal Network," "Host," and "Application" layers before reaching the **Data**.
- **The Layers (from Outside to Inside):**
 1. **External Network:** Firewalls and edge protection.
 2. **Internal Network:** Network segmentation and IDS/IPS.
 3. **Host:** Antivirus and OS hardening on servers/PCs.
 4. **Application:** Secure coding and software patches.
 5. **Data:** Encryption and access control (The heart of the system).

- In Figure 5, you can see an example of layers you might want to put in place to defend your assets.



11. Differentiate between physical and logical assets in the context of information security.

1. Physical Assets (Tangible)

These are the **physical, touchable objects** that an organization owns. If these are stolen or damaged, the system cannot function.

- **Definition:** The hardware and infrastructure of a system.
- **Protection Method:** Locks, CCTV, Security Guards, Biometrics.
- **Examples:**
 - Servers and Computers.
 - Data Centers and Buildings.
 - Routers, Switches, and Cables.
 - Backup Tapes/Hard Drives.

2. Logical Assets (Intangible)

These are **non-physical assets** that exist inside the systems. These are often the "Data" or "Information" that hackers are actually looking for.

- **Definition:** The digital information and software stored on physical hardware.
- **Protection Method:** Encryption, Passwords, Firewalls, Access Controls.
- **Examples:**
 - Customer Databases.
 - Intellectual Property (Trade secrets, source code).
 - System Software and Applications.
 - Digital Files (PDFs, Spreadsheets).

Aspect	Physical Assets	Logical Assets
Definition	Tangible items that you can physically touch	Intangible assets related to data and software
Nature	Hardware-based	Data / Software-based

Aspect	Physical Assets	Logical Assets
Examples	Servers, computers, routers, hard drives	Databases, software, passwords, digital data
Security Risk	Theft, damage, fire, natural disaster	Hacking, data breach, malware
Protection Method	Physical security (locks, CCTV, guards)	Cyber security (encryption, firewall, authentication)
Visibility	Visible and touchable	Not visible, exists digitally
Damage Impact	Hardware loss or destruction	Data loss, corruption, unauthorized access

Crypto Basics (Lecture-03)

12. What is Kerckhoffs' Principle? Why is it important in cryptographic system design?_

Kerckhoffs' Principle:

"A cryptographic system should remain secure even if everything about the system, except the key, is public knowledge." □ This is known as Kerckhoffs' Principle.

Broader Interpretation of Kerckhoffs' Principle

A secure system should depend on **secret keys or passwords**, not on keeping the system design secret.

The design can be public, but the **key must be secret and changeable**.

Example: OpenSSL is secure even though its code is public, because security depends on keys.

Importance:

It is important because a cryptographic system should stay **secure even if the algorithm is public**. Only the **key must be secret**, so the system remains safe, testable, and easy to update.

13. Describe the basic process of encryption and decryption in a cryptosystem.

🔒 Basic Process of Encryption and Decryption (Exam-Friendly)

Encryption:

Plaintext (original message) is converted into **ciphertext** using an **encryption algorithm and a key** to keep the data secret.

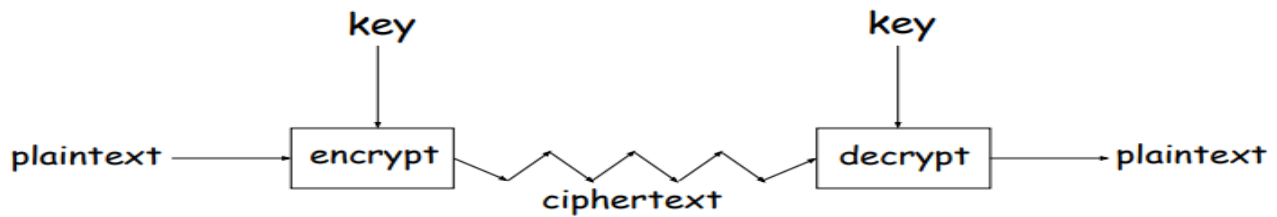
- **Decryption:**

Ciphertext is converted back into **plaintext** using a **decryption algorithm and the correct key**.

Flow:

🔗 Plaintext → Encryption + Key → Ciphertext → Decryption + Key → Plaintext

Crypto as Black Box



A generic view of symmetric key crypto

14. Explain the difference between symmetric and public key cryptosystems.

Symmetric Key Cryptosystem

Uses **one same key** for encryption and decryption

Key must be **shared secretly**

Faster and efficient

Example: **AES, DES**

Public Key Cryptosystem

Uses **two different keys** (public & private)

Public key is shared, **private key is secret**

Slower than symmetric

Example: **RSA, ECC**

15. What is a Caesar cipher? Describe its encryption and decryption processes.

OR

16. A plaintext message "HELLO" is encrypted using a Caesar cipher with a shift of 3. Write the ciphertext.

A **Caesar cipher** is a **simple substitution cipher** where each letter of the plaintext is shifted by a fixed number of positions in the alphabet.

◆ Encryption Process:

- Choose a **key (shift value)**, say **n = 3**
- Shift each letter **forward** by 3 positions

Example:

A → D, B → E, C → F

Plaintext: **HELLO**

Ciphertext: **KHOOR**

◆ Decryption Process:

- Use the **same key (n)**
- Shift each letter **backward** by n positions

Example:

K → H, H → E, O → L, O → L, R → O

Ciphertext: **KHOOR**

Plaintext: **HELLO**

17. A Caesar cipher with a shift of $n=4$ produces the ciphertext "CSYEVIXIVQMREXIH". Decrypt this ciphertext to recover the plaintext

Ans: Kore nao. Correct answer = **YOUARETERMINATED**

18. What is the total number of possible keys in a Caesar cipher? Show the calculation

Answer:

☞ The total number of possible keys in a **Caesar cipher** is **26**.

☛ Calculation:

- The English alphabet has **26 letters**
- Each key represents a shift from **0 to 25**

Total keys=26

👉 Explanation (Easy):

- Shift 0 → no change
- Shift 1 → A → B
- ...
- Shift 25 → A → Z

So, there are **26 possible shifts (keys)**.

🔪 One-line Exam Answer:

☞ A Caesar cipher has **26 possible keys**, equal to the number of letters in the English alphabet.

19. Discuss the limitations of the Caesar cipher and how it can be attacked

✗ Limitations:

❑ **Very small key space** – Only **26 possible keys**, so it's easy to guess.

❑ **Same shift for all letters** – Patterns remain visible.

❑ **No security for modern use** – Too simple to protect real data.

✗ How it can be attacked:

❑ **Brute-force attack**

☞ Try all 26 shifts; the correct plaintext appears quickly.

❑ **Frequency analysis**

☞ Letter patterns (like E, T, A) help attackers find the shift.

🔪 One-line Exam Answer:

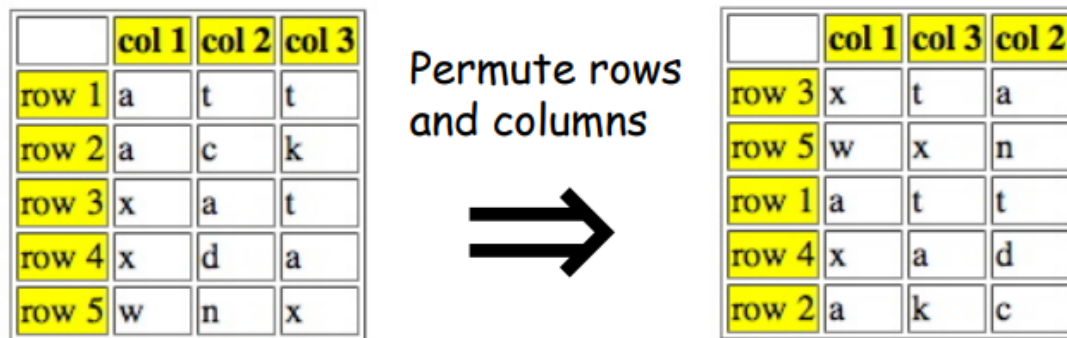
👉 The Caesar cipher is weak because it has only 26 keys and can be easily broken using brute-force or frequency analysis.

20. Encrypt the message “welcome to cse ju” using a double transposition cipher with 4 rows and 4 columns, using the row permutation $(1,2,3,4) \rightarrow (2,4,1,3)$ and the column permutation $(1,2,3,4) \rightarrow (3,1,2,4)$.

Answer: Self Task. Like below example

Double Transposition

□ Plaintext: **attackxatxdawn**



□ Ciphertext: **xtawxnattxadakc**

□ Key is matrix size and permutations:
 $(3,5,1,4,2)$ and $(1,3,2)$

21. Suppose you are given a one-time pad = 111 101 110 101 111 100 and alphabet encodings,

ALPHABET	E	H	I	K	L	R	S	T
T								
BINARY	000	001	010	011	100	101	110	111

Now determine the ciphertext for the following plaintexts

- THRILL
- TILLER

Crypto Part II

22. What is a stream cipher? Provide examples of situations where it is used.

A stream cipher is a type of symmetric key encryption algorithm that encrypts data one bit or one byte at a time. It generates a keystream from a secret key, and then combines this keystream with the plaintext using the XOR operation to produce ciphertext.

Encryption Formula: $\text{Ciphertext} = \text{Plaintext} \oplus \text{Keystream}$

The same keystream is used during decryption to recover the original plaintext.

Examples of Situations Where Stream Cipher is Used

1. Secure Mobile Communication • Example: A5/1 used in GSM networks.
2. Wireless Network Security (Older Systems) • Example: RC4 used in WEP.
3. Secure Web Communication (Older Protocols) • RC4 was previously used in SSL/TLS.
4. Real-Time Applications • Voice calls • Video streaming • Online gaming (Because stream ciphers are fast and suitable for real-time data)

23. Describe the structure and operation of the DES algorithm, including its key size and block size.

The **Data Encryption Standard (DES)** is a symmetric-key block cipher published by the National Institute of Standards and Technology (NIST). It is based on the **Feistel Network** structure.

1. Key and Block Size

- **Block Size:** DES encrypts data in fixed-sized blocks of **64 bits**. This means 64 bits of plaintext are processed to produce 64 bits of ciphertext.
- **Key Size:** The nominal key length is **64 bits**. However, every 8th bit is used for parity checking, making the **effective key length 56 bits**. The security of DES depends entirely on these 56 bits.

2. The Structure of DES

The DES algorithm follows a specific sequence of functional steps:

A. Initial Permutation (IP)

Before the main processing begins, the 64-bit input block undergoes an **Initial Permutation**. The bits are rearranged according to a predefined table. This step does not provide security but prepares the data for the rounds.

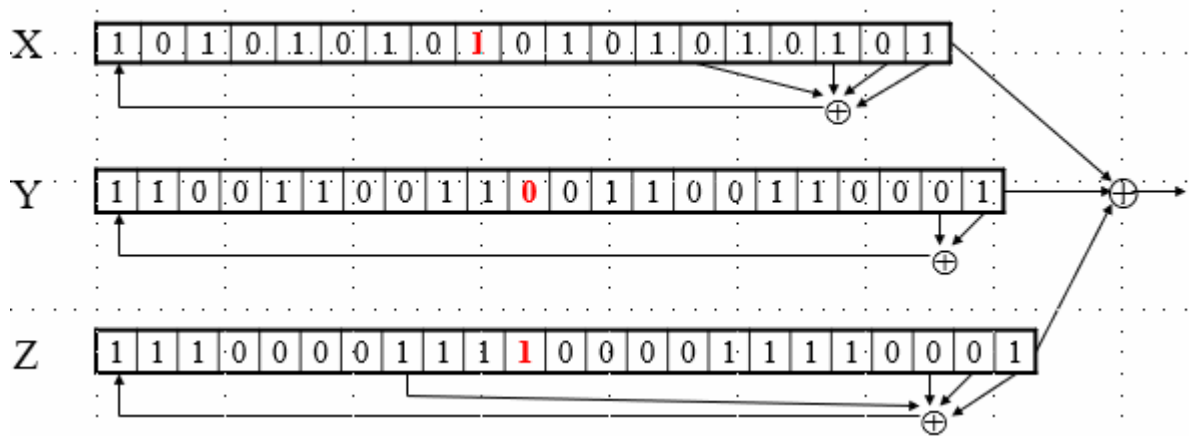
B. The 16 Rounds of Processing

DES performs **16 rounds** of the same operation. In each round, the 64-bit block is divided into two 32-bit halves: **Left (\$L\$)** and **Right (\$R\$)**.

- **Expansion:** The 32-bit R half is expanded to **48 bits**.
 - **Key Mixing:** The expanded 48-bit block is XORed with a **48-bit subkey** (generated from the main 56-bit key).
 - **Substitution (S-Boxes):** The 48-bit result is fed into 8 **S-Boxes**, which transform it back into **32 bits**. This is the most crucial step as it provides **non-linearity (Confusion)**.
 - **Permutation (P-Box):** The 32-bit output from the S-Boxes is shuffled using a **P-Box** to provide **Diffusion**.
 - **XOR and Swap:** The result is XORed with the L half. The two halves are then swapped for the next round.
- C. Final Permutation (IP-1)

After all 16 rounds are completed, a final permutation is performed. This is the exact **inverse of the Initial Permutation**. The output of this stage is the final **64-bit Ciphertext**.

7. What role do S-boxes play in block ciphers like DES?
8. Explain the difference between stream ciphers and block ciphers.
9. How does the A5/1 stream cipher generate its keystream? Include a brief explanation of its shift registers.
10. The A5/1 cipher uses three shift registers X, Y, Z with lengths of 19, 22, and 23 bits, respectively.



Suppose the majority function mmm at a specific time is computed as: $m = \text{maj}(X[8], Y[10], Z[10])$

Given the initial states: $X[8]=1$, $Y[10]=0$, $Z[10]=1$. Compute the value of m , determine which registers will step, and calculate the new state of X if its feedback polynomial is: $t = X[13] \oplus X[16] \oplus X[17] \oplus X[18]$

11. If we generate a sufficiently long keystream, the keystream must eventually repeat. Why?
12. Why is it a security concern if the keystream repeats?
13. Answer the following questions
 - a. On average, how often does the X register step?
 - b. On average, how often does the Y register step?
 - c. On average, how often does the Z register step?
 - d. On average, how often do all three registers step?
 - e. On average, how often do exactly two registers step?
 - f. On average, how often does exactly one register step?

Crypto Part III (Lecture 5)

14. What improvements does AES offer over DES? List its key features and block size.
15. Suppose you have the following S-block of a DES model.

Column →	0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15
Row 0	14	4	13	1	2	15	11	8	3	10	6	12	5	9	0	7
Row 1	0	15	7	4	14	2	13	1	10	6	12	11	9	5	3	8
Row 2	4	1	14	8	13	6	2	11	15	12	9	7	3	10	5	0
Row 3	15	12	8	2	4	9	1	7	5	11	3	14	10	0	6	13

Now, for the input sequence 101101, answer the following.

- i. Which row contains the output value?
- ii. Which column contains the output value?
- iii. What will be the value of the output in decimal?

- iv. What will be the value of the output in binary?
16. Describe the four functions used in an AES encryption round.
17. Compare ECB (Electronic Codebook) and CBC (Cipher Block Chaining) modes of operation. Highlight their advantages and disadvantages.
18. What is the purpose of an initialization vector (IV) in CBC mode?
19. Explain the concept of a Message Authentication Code (MAC). How does it ensure data integrity?
20. A digital signature provides for data integrity and a MAC provides for data integrity. Why does a signature also provide for non-repudiation while a MAC does not?
-

General Cryptography

21. RSA Key Generation

Let $p=11$ and $q=13$. Compute the modulus N , Euler's totient $\phi(N)$, and find a valid public key exponent e such that $\gcd(e, \phi(N))=1$.

22. RSA Encryption

Using the RSA public key ($N=143, e=7$), encrypt the message $M=10$. Show all steps.

23. RSA Decryption

Using the private key $d=103$ and modulus $N=143$, decrypt the ciphertext $C=100$. Show the complete calculation.

24. Diffie-Hellman Key Exchange

Alice and Bob use the Diffie-Hellman key exchange with $p=23$ and $g=5$. If Alice selects her private key $a=6$ and Bob selects $b=15$, compute the shared secret key K .

25. Knapsack Encryption

Given the superincreasing knapsack $(2, 3, 7, 14)$, a modulus $n=31$, and a multiplier $m=5$, compute the general knapsack.

26. Knapsack Decryption

Using the general knapsack $(10, 15, 5, 8)$ and ciphertext $C=23$, decrypt the message to retrieve the binary sequence.

27. ECC

A digital signature provides for data integrity and a MAC provides for data integrity. Why does a digital signature also provide for non-repudiation

while a MAC does not? Consider the elliptic curve $E : y^2 = x^3 + 7x + b \pmod{11}$.

- a. Determine b so that the point $P = (4,5)$ is on the curve E .*
 - b. Using the b found in part a, list all points on E .*
 - c. Using the b found in part a, find the sum $(4,5) + (5,4)$ on E .*
 - d. Using the b found in part a, find the point $3(4,5)$.*
-

Hashing

28. What are the properties of a Cryptographic Hash Function?
 29. State the applications of Hash function.
 30. Draw the block diagram of SHA-3.
-

Access Control

31. Evaluate the limitations of traditional password-based authentication in terms of human usability, scalability, and vulnerability to attacks.
32. Assess the use of biometrics for authentication. What trade-offs exist between user convenience, error rates, and security?
33. Describe how a salted hash strengthens password security and explain how it mitigates precomputed dictionary attacks.
34. Discuss the advantages and risks associated with single sign-on (SSO) systems. How do they improve user experience, and what vulnerabilities do they introduce?
35. In the context of biometrics, define the terms fraud rate and insult rate. In statistics, which of these is a Type I error and which is a Type II error?
36. Suppose all passwords on a given system are 8 characters and that each character can be any one of 64 different values. The passwords are hashed (with a salt) and stored in a password file. Now suppose Trudy has a password cracking program that can test 64 passwords per second. Trudy also has a dictionary of 230 common passwords and the probability that any given password is in her dictionary is $1/4$. The password file on this system contains 256 password hashes.
 - a. How many different passwords are possible?
 - b. How long, on average, will it take Trudy to crack the administrator's password?
 - c. What is the probability that at least one of the 256 passwords in the password file is in the dictionary?
 - d. What is the expected work for Trudy to recover any one of the passwords in the password file?